정보보안

2장. 시스템 보안

사용자 명령 인터페이스(cmd, bash)를 통해 system call을 한다.
`프로세서 관리자`, `메모리 관리자`, `장치 관리자`, `파일 관리자`, `네트워크 관리자`를 호출하여 기능을 수행한다.

서버 운영체제로 크게 `윈도우 서버`, `리눅스 서버`가 유명하며 이러한 서버 운영체제는 웹, DB, 메일 서버 등으로 사용된다.
서버 운영체제와 단일 사용자 운영체제는 용도에 맞게 차이점이 있으며 서버 운영체제의 경우 고성능, 고효율이 가장 큰 특징이다.

윈도우의 발전 과정

MS-DOS : 텍스트 기반
이후 윈도우 운영체제는 GUI 기반 운영체제 지원한다. 윈도우 XP는 서버 운영체제인 윈도우 NT4.0의 기술을 도입하여 기능이 좋아지고, 윈도우 7은 서버 운영체제인 윈도우 2008의 기능을 도입하여 좋아졌다. (하여 많이 사용한 개인용 운영체제로 XP, 7이 주로 사용되었다.)

윈도우 부팅 순서(윈도우 XP)

1. `POST(Power On Self Test) 시행` : 하드웨어가 잘 붙어있는지 확인한다.
2. `BIOS를 통해 기본 부팅 관련 설정 로드` : 시스템 설정 사항 확인

---

3. `MBR 로드` : 부팅 매체에 대한 기본 파일 시스템 정보 로드, 소프트웨어이기에 공격당하기 쉽다. 또한 메모리의 첫번째 섹터에 위치하기에 공격할 지점을 정확히 알 수 있다.
4. `NTLoader 실행` : 가능한 부팅 옵션을 보여주는 용도
5. `NTDetect 실행` : 하드웨어 검사(CPU 버전 등)
6. `ntoskrnl.exe 실행`

윈도우 부팅 순서(윈도우 7)

1,2,3 단계는 윈도우 XP와 동일
4. `bootmgr.exe 실행` : 실행 가능한 운영체제 목록을 보여줌
5. `Winload.exe 실행` : NTDetect, ntoskrnl 실행

리눅스 부팅 순서

쉘을 통해 명령을 입력하고 커널에 명령을 전달한다. 우리가 주로 사용하는 쉘은 본어게인쉘로 `bash` 라는 쉘을 사용한다.
1,2,3 단계는 동일
4. Boot Loader 실행
5. 배포판마다(Ubuntu, CentOS, 레드햇 등) 방식이 다를 수 있지만 실행 레벨에 따라 서비스를 실행한다.

시스템 보안 6가지

1. 계정
   계정에 대한 인증수단을 관리한다. : 비밀번호, 지문, 홍채 등 여러 인증방법을 결합하여 계정을 관리한다.
   윈도우 계정 관리 :
   관리자 = Administrator, 관리자 그룹 = Administrators
   사용자 = User, 사용자 그룹 = Users
   그룹을 통해 사용자를 관리하면 관리하기에 용이하다. 그 그룹에 속한 사용자들에게 공통된 권한 부여 가능
   `net` 명령어를 통해 cmd에서 확인 가능
   1. net user
   2. net localgroup
   3. net localgroup administrators
   기본적으로 윈도우는 `Administrators` , `Users` , `System` , `Guests` , `Power Users` , `Backup Operators` 등의 그룹이 존재하고 Guests 그룹은 사라지는 추세이다.
   리눅스 계정 관리 :
   중소형 서버용 운영체제로 사용되며 관리자 = root, 관리자 그룹 = root라는 이름을 가진다. roots가 아님을 유의하자.
   계정의 목록을 확인하는 방법 `cat ~/etc/passwd` 여기서 cat 명령어는 파일을 출력하는데 사용하는 명령어이다.
   파일 편집 명령어는 `vi` , `vim` 등이 존재한다.
   계정이름:비밀번호:유저아이디:그룹아이디:홈디렉토리:사용자기본쉘경로

```
root@ip-172-31-2-244:~# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106::/nonexistent:/usr/sbin/nologin
syslog:x:104:110::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:112::/run/uuidd:/usr/sbin/nologin
tcpdump:x:108:113::/nonexistent:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
landscape:x:110:115::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:111:1::/var/cache/pollinate:/bin/false
fwupd-refresh:x:112:116:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
ec2-instance-connect:x:113:65534::/nonexistent:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
mysql:x:114:120:MySQL Server,,,:/nonexistent:/bin/false
root@ip-172-31-2-244:~#
```

DB 계정 관리

기본 관리자 계정은 ms-sql : sa, mysql : root, 오라클 : sys, system이라는 이름을 가진다.

응용프로그램을 설계한 개발자의 실수를 노려 DB서버에 침투하는 것이 일반적이다.

2. 세션

세션이란 사용자와 또 다른 컴퓨터가 연결된, 활성화된 상태 를 말한다.

방지하기 위한 방법 : 화면보호기, 암호화, 잠금모드 등

3. 접근

접근을 제어한다는 것은 적절한 권한을 가진, 즉 인가된 사용자만 접근하여 정보를 가져갈 수 있도록 하는 것이며, 시스템과 네트워크는 IP와 프로그램의 포트 를 통하여 접근을 어느정도 제어할 수 있다.

기본적인 포트번호

1. 텔넷 : 23
2. SSH : 22
3. FTP : 21
4. HTTP : 80
5. HTTPS : 443
6. 윈도우터미널서비스 : 3389

7. mysql : 3306
   이 중 암호화하지 않는 서비스는 Telnet(23), FTP(21)이 있다. 많이 사용하지 않는 추세이지만, `inetd` 라는 데몬 프로그램을 통해 (일종의 방화벽) 어느정도 접근을 제어할 수 있다.
   DB는 접근 가능한 IP 영역대를 지정하며, 웹서버의 경우 IIS, 아파치에서 IP 접근 제어를 제공한다.

4. 권한
   권한은 위의 계정관리와 비슷한데 파일, 디렉토리의 읽고쓰는 권한을 관리하는 방법이다.
   리눅스에서 파일은 기본적으로 `-l` 이라는 옵션을 통해 파일의 권한을 확인할 수 있다.

```
root@ip-172-31-2-244:/home# ls ./ubuntu/ -l
total 4
-rw-rw-r-- 1 ubuntu ubuntu 1009 Oct 14 17:07 linuxTest.py
root@ip-172-31-2-244:/home#
```

   10개의 문자 중 디렉토리일 경우 d, 파일일 경우 -로 표시되며 그 이후 3개씩, 소유자, 그룹, 다른사람의 권리를 나타낸다.
   `r : 읽기, w : 쓰기, x : 실행`
   chmod 777 file을 통해 파일의 권한을 설정할 수 있다.
   사용자의 권한은 /etc/sudoers 파일에 접근하여 수정한다.

5. 로그
   관리자가 감시하고 있을 때 해킹이 발생하기는 쉽지않다. 대부분의 해킹은 관리자가 자리를 비울 때 발생한다. 그렇기에 기록에 대한 로그를 남겨 문제가 생겼을 때 해결 할 수 있도록 한다.
   로그는 주로 AAA를 추적한다. 여기서 AAA는 인증(Authentication), 인가(Authorization), 기록(Account)를 말한다.
   리눅스의 로그는 `~/var/log` 폴더안에 들어있다.
   주요로그
   1. utmp : 현재 로그인한 사용자의 상태정보 ($ who)

```
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
ubuntu   pts/0    220.67.124.111   16:36    1.00s  0.06s  0.01s sshd: ubuntu [priv]
```

   2. wtmp : 로그인/로그아웃 성공한 정보를 출력 ($ last)

```
root@ip-172-31-2-244:/var/log# \last
ubuntu   pts/0        220.67.124.111   Mon Oct 23 16:36   still logged in
ubuntu   pts/0        13.209.1.60      Fri Oct 20 18:16 - 18:19  (00:03)
ubuntu   pts/0        220.67.124.111   Sat Oct 14 17:26 - 17:30  (00:04)
ubuntu   pts/0        220.67.124.111   Sat Oct 14 16:46 - 17:15  (00:28)
ubuntu   pts/0        220.67.124.111   Sat Oct 14 16:09 - 16:29  (00:20)
reboot   system boot  5.15.0-1036-aws  Sat Oct 14 16:08   still running
```

   3. btmp : 실패한 로그인 시도에 대한 기록을 출력 ($ lastb)
   4. syslog : 유닉자

3장. 네트워크 보안

OSI 7 Layers by ISO(Internation Organization for Standard)

1. 물리계층 2. 데이터링크계층 3. 네트워크계층 4. 트랜스포트/전송 계층 5. 세션 계층 6. 표현 계층 7. 어플리케이션 계층으로 이루어져 있으며 인터넷 프로토콜은 OSI 7 레이어의 5,6 계층을 제외한 5계층을 사용한다.
2. 물리 : 비트를 물리적으로 전송, 전선의 용도에 따라 분류된다. CAT5 또는 CAT6 전선을 사용하며 선에 따라 UTP, STP, STP로 나뉜다. 주로 UTP를 시중에서 많이 사용한다.
3. 데이터링크 : 이더넷, 무선 전송, MAC 주소 사용, 스위치를 통해서 전달한다.
4. 네트워크 : IP, 데이터그램 전달하며 IANA라는 표준기구에서 IP를 제공하는데, $(2^8)^4$로 약 40억개의 IP주소를 할당하지만, 이는 현재 턱없이 부족하기에 사설 IP를 사용한다. 하나의 네트워크 안에서 내부목적으로 사용하는 사설 IP주소로는 `172.~`, `10.~`, `192.168.~` 이 있다.
5. **전송**: TCP/UDP, 세그멘테이션
   TCP는 순서보장, 에러제어 등 신뢰성있는 통신을 제공하는 프로토콜 이다.
   TCP 3단계는 연결, 전송, 종료로 이루어진다.
   연결 : SYN(클라이언트) SYN+ACK(서버) ACK(클라이언트) 3단계로 이루어진다.
   전송 : DATA(서버) ACK(클라이언트)
   종료 : FIN(클라이언트) ACK(서버), FIN(서버), ACK(클라이언트)
   TCP 기반 서비스는 TCP 포트가 존재하며 유명한 포트로는 Telnet(23), SSH(22), FTP(21), HTTP(80), HTTPS(443), POP3(110), 등이 있다.
6. 어플리케이션 : HTTP, FTP, SSH, SMTP 등

보안 공격의 유형
수동적 공격, 적극적 공격으로 나뉘며 수동적공격은 직접적인 타격이 없어 탐지가 어렵다는 단점이 있고, 적극적 공격은 탐지는 쉽지만 피해가 크다는 단점이 존재한다. 수동적 공격으로 도청, 스니핑, 스푸핑 기법이 있으며 적극적 공격으로 DOS, 랜섬웨어 등 다양한 보안 공격이 존재한다.

능동적/적극적 공격 DOS 유형

1. 네트워크의 대역폭 공격 : TCP SYN flooding, ICMP/UDP flooding
2. 서버 트래픽 공격 : HTTP GET flooding

적극적 공격 DoS

1. TearDrop 공격
   TCP의 허점을 공격하는 서비스로 TCP는 순서보장이라는 신뢰성 있는 통신을 제공한다. 하여 시퀀스 번호가 중요한데 일부로 보냈던 데이터를 다시 보내거나 중간에 몇개의 시퀀스 번호를 가진 데이터를 의도적으로 빼서 재전송을 하게 만들고 자원을 고갈시킨다.
   → 반복되는 패킷은 무시한다. 진짜 제대로 된 데이터라면 그 때 다시 요청하면 된다.

2. LAND 공격
   네트워크를 과부하 시키는 방법으로 네트워크계층에서는 보내는 사람의 IP, 받는 사람의 IP를 헤더에 담는데 보내는 사람과 받는 사람의 IP를 갖게 하여 서버의 부하를 늘리는 방법이다.
   → 사전에 방지하면 된다. 같은 IP라면 다른 네트워크를 타지 않도록 만든다. 방화벽 등 다양한 방법으로 해결
3. Ping of Death
   기본적으로 운영체제는 ping 서비스를 제공한다. 특정 IP까지 왕복하는데 걸리는 시간을 제공하고 기본적으로 32byte의 작은 패킷을 보내 시간을 체크한다. 하지만 의도적으로 패킷을 크게 보내어 서버에 과부하를 주는 방법이다. TCP는 큰 데이터에 대하여 세그멘테이션을 통해 보다 작은 세그먼트로 분할하여 보내기에 서버에 많은 트래픽이 발생한다.
   → Ping 서비스를 막는다.
4. SYN flooding
   TCP 기반 서비스들은 TCP 연결을 하기위해 SYN 패킷을 보내야 하는데, 클라이언트가 SYN을 보내고 서버는 그에 대한 응답으로 SYN+ACK 패킷을 클라이언트에게 보낸다. 하지만 의도적으로 클라이언트는 그에 대한 응답인 ACK를 보내지 않으므로서 서버를 기다리게한다.
   → 대기큐를 늘리거나, 기다리는 시간을 감소한다.
5. HTTP GET flooding
   웹사이트 url을 통해 자원을 요청하는 방식을 HTTP GET 메소드라고 한다. GET 요청을 과부하게 주어 웹 서버에 부하를 준다.
   → GET 요청 한계를 정한다.
6. HTTP CC 공격
   웹 서비스는 대부분의 클라이언트가 요청하는 리소스에 대하여 프록시 서버를 만들어 빠르게 자원을 제공한다. 이는 사용자의 캐시와 관련이 있다. 이점을 이용하여 캐시를 사용하지 않고 요청을 하여 서버에 직접적으로 접근하는 횟수를 늘려 서버에 과부하를 준다.
7. 동적 HTTP 요청 flooding
   대부분의 서비스 관리자는 GET flooding을 요청하는 것을 알기에, GET 방식에 대해서 제한을 둔다. 하지만 동적으로 GET, POST, PUT등 요청을 하여 이게 실제 사용자인지, 의도적인것인지 헷갈리게 공격한다.
8. 슬로헤더 HTTP 공격
   웹서비스의 GET 방식의 경우 HTTP 헤더만 포함하여 요청을 하는데, 이를 의도적으로 크게 하여 잘게 나누고, 천천히 보내어 서버의 자원을 소비하는 공격이다.
9. 슬로헤더 HTTP POST 공격
   슬로헤더 공격과 마찬가지로 POST 요청시 HTTP 헤더와 더불어 HTTP 바디를 포함하는데 바디안에 있는 데이터를 의도적으로 천천히 보내 서버의 자원을 소비시킨다.
10. Smurf 공격

의도적으로 ICMP 패킷을 브로드캐스트하여 네트워크에 부하를 주는방법이다.

11. Mail Bomb 공격
    메일을 의도적으로 많이 전송하여 정상적인 메일을 수신할 수 없도록 한다. 이는 개인이 공격대상이 될 수 있다.
12. DDoS 공격
    악성코드와 결합한 형태로, 천천히 컴퓨터들을 감염시켜 봇을 만든다. 이러한 봇들이 모여 봇넷이 구성되고 어느 시점에 전체적으로 공격대상에게 공격을 퍼붇는다.

수동적 공격

1. 스니핑 : 데이터의 흐름속에서 정보를 찾는 행위
    1. 스위치 포트 미러링
       스위치는 주로 24, 48개의 포트를 꼽을 수 있도록 제공되며 mirror 포트가 있는데, 이는 주로 관리자가 문제가 생겼을 때 확인하는 용도로 사용한다. 하지만 의도적으로 해커가 선을 꼽아 작은 컴퓨터에 로그를 기록하면 그 스위치가 포함된 네트워크의 모든 데이터 흐름이 해커에게 들어간다.
    2. 스위치 재밍 공격
       스위치는 처음엔 브로드캐스트 전송을 통해 수신자를 찾게 되는데, 이는 발전하여서 자주 보내는 맥 주소를 주소 테이블에 매칭할 수 있도록 하여 빠른 전송을 가능하도록 하였다. 하지만 의도적으로 랜덤한 수신자에게 MAC 패킷을 보내 주소 테이블의 기능을 잃게 만들고, 결국 모든 컴퓨터들이 브로드캐스트 전송을 하여 느리게 만든다.
       → 한번 설정된 주소 테이블은 바뀌지 않도록 한다. 정적 주소 테이블
2. 스푸핑 : 공격자가 자신이 수신자인 것 처럼 위장
    1. ARP 스푸핑
    ARP 프로토콜은 IP주소를 MAC 주소로 매핑하는 프로토콜인데, 같은 네트워크 안에서는 굳이 라우터를 경유할 필요가 없기에, MAC 주소를 통해 서로 데이터를 주고 받는데 공격자가 중간에서 송신자, 수신자에게 잘못된 MAC주소를 알려주고, 대신 송수신한다.
    → 중간에 ARP 테이블을 두고 감시한다. 완벽한 대책이 어렵다.
    2. IP 스푸핑
    주로 트러스트 상황에서 위협적인데, 트러스트란 특정 서버가 인가된 IP에 대해서는 인증을 위한 수단을 받지 않는다.(ID, PW 등) 이러한 허점을 이용하여 공격자가 트러스트 IP를 탈취 후 서버의 불법으로 침입한다.
    근데 이는 웹 성능 테스트로 사용되기도 한다.
    → IP 트러스트 미사용, 패킷 필터링
    3. ICMP 리다이렉트 공격
    ICMP 패킷은 제일 효율적인 경로를 찾기위한 프로토콜이기도 한데, 이를 의도적으로 해커가 자신한테 보내는 경로가 제일 빠르다고 알려준다. 그렇게 되면 앞으로 데이터의 전송은 해커에게 하게 되고, 해커는 들키지 않기위해 송수신을 대신해준다.

4. DNS 스푸핑
DNS란 도메인 네임을 해당 IP 주소로 매핑하는 서비스이고, 이를 위해 클라이언트는 해당 도메인을 DNS 서버에 보내 IP 주소를 받아야 한다. 하지만 이 과정에서 중간에 해커가 도메인에 대한 잘못된 IP를 클라이언트에게 미리 제공하고 위조 사이트로 연결하게끔하여, 개인 정보를 탈취한다.
하이재킹
1. 세션 하이재킹 : 활성화된 상태 자체를 가로챈다.
2. TCP 세션 하이재킹 : ARP 스푸핑을 이용한다.
→ 암호화를 통해 해결한다 Telnet이 아닌 SSH를 사용한다.

무선 네트워크 보안
무선 랜 프로토콜로는 802.11b(WIFI), 802.11.g, 802.11.n을 주로 사용하며 AP를 잘 관리해야 한다. 주로 AP는 공유기와 비슷하다고 볼 수 있으며, SSID 브로드캐스트하는데 적절히 전파 범위를 설정하여 외부에서 침입할 수 없도록 한다. 아니면 일종의 인증 시스템을 RADIUS 서버에게 일임하여 인증을 걸친다.

4장. 웹 보안

클라이언트는 웹브라우저를 통해 웹서버에 요청하고, 웹 서버는 기본적인 데이터 외 복잡한 데이터의 경우 DB서버에 요청한다.
Client는 TCP를 통해 서버와 Connection을 생성하고, Request를 보낸다. 이에 대한 응답으로 서버는 Response를 보내준다.

HTTP 동작 방식은 기본적으로 상태를 유지하지 않는 stateless 한 프로토콜이기에, 이전 연결에 대한 정보를 가지고 있지 않는다.

1. 비지속 HTTP 연결 : 하나의 연결에선 하나의 리소스만 전달한다.
2. 지속 HTTP 연결 : 한번의 연결을 통해 여러 리소스를 전달 , 성능이 우수

HTTP 요청 및 응답 메시지

```
Request Header:
GET / HTTP/1.1
Host: www.msaleh.co.cc
User-Agent:Mozilla/5.0 (Windows; U; Windows
NT 5.1; en-US; rv:1.9.0.10)
Gecko/2009042316 Firefox/3.0.10
Accept: */*
Connection:close

Response Header:
HTTP/1.1 200 OK
Date: Sat, 09 May 2009 12:27:54 GMT
Server: Apache/2.2.11 (Unix)
Last-Modified: Thu, 12 Feb 2009 15:29:42
GMT
Etag: "c3b-462ba63a46580"-gzip
Cache-Control: max-age=1200, private,
proxy-revalidate, must-revalidate
Expires: Sat, 09 May 2009 12:47:54 GMT
Accept-Ranges: bytes
Content-Length: 976
Content-Type:text/html
```

현재 HTTP2.0 버전까지 나왔지만 상용화되는 버전은 HTTP1.1버전이다.

주요 응답 상태코드
200번대 (성공) : 200(OK), 201(Created), 202(Accepted)
300번대(리다이렉션) : 페이지가 변경되었음과 관련된 상태코드
400번대(클라이언트 오류) : 400(문법오류), 404(요청자료 존재X), 403(접근 차단), 401(인증 오류)
500번대(서버 오류) : 500(서버내부오류발생), 501(해당 메서드 실행 불가)

비지속 연결상태에서 세션을 계속 유지하기 위해 대부분의 웹사이트에서는 쿠키를 지원한다. 쿠키는 키밸류로 이루어져 있으며, 클라이언트가 파일로 관리하고, 서버는 DB에 저장한다. 처음 요청을 보내면 서버는 쿠키를 보내주고, 클라이언트는 쿠키를 저장한다. 추후 다시 요청할 때 이 쿠키를 들고 서버에 요청하면 서버는 DB에 쿠키를 저장하고 사용자의 인증 수단으로 사용한다.

또한 웹서버는 빠른 응답속도, 즉 성능을 개선하기 위해 자주 사용하는 리소스에 빠르게 응답할 수 있도록 웹 캐시(프록시) 서버를 운영한다. HTTP 헤더에는 내가 받는 자원이 언제 바껴는지에 대한 정보가 들어있고, 최신화 되어있다면 프록시는 실제 서버에게 새로운 데이터를 요청하는 식으로, 서버에 대한 부하를 줄이고 성능을 높인다.

SSS vs CSS
서버 사이드 스크립트는 동적인 페이지를 제공하는 스크립트로 asp, jsp 등이 있으며 최근 python, java 등으로도 사용가능하다.
클라이언트 사이드 스크립트는 웹 브라우저에 의해 해석되고 실행되는 스크립트로 자바스크립트, html, css 등이 있다

URL에는 영어와 숫자로 된 ASCII 코드를 지원하는데 한국과 같은 다른 국어에서는 이를 표현할 수가 없기에 퍼센트 인코딩, base64 인코딩을 통해 문자를 바이트 단위 16진수로 표현한다.

해마다 웹 보안 취약점에 대해 올리는 기구 OWASP (Open Web Application Security Project)
인젝션, XSS, 등등 → 웹 개발자가 되고 싶다면 확인해보는 것이 좋다.

중간고사

7장. 웹보안

DNS*(Domain Name Service)
인터넷에서 사용하는 식별자는 IP 주소로 32bit로 이루어져 있음.(IPv4)
이는 숫자로만 되어 있어 기억하기 어렵기 때문에 IP에 대응되는 네임을 지어줌.

DNS는 주소 네임을 IP 주소로 변환해주는 서비스이며, `애플리케이션 계층` 프로토콜이다.

> **△ 하나의 이름에 여러개의 IP를 할당할 수 있을까?**
>
> 할당할 수 있다.

DNS서비스는 많은 트래픽과 도메인 서버와의 거리가 먼 경우, 유지보수의 측면으로 Distribution하고 계층형으로 설계한다.

DNS 공격

1. DDos 공격 : 루트 DNS 서버에 과도한 부하를 준다. 주로 ping을 통해 ICMP 프로토콜을 이용한다.
    1. 이를 해결하기 위한 대안으로 캐시를 통해 루트 DNS 서버의 부하를 줄이고 핑 메시지를 차단할 수 있다.
2. 사용자가 주소이름을 DNS 서버에게 해당 IP주소로 변환해달라고 요청시 공격자가 반환하는 IP주소를 가로채 다른 주소로 보내도록 할 수 있는데 너무 짧은 시간이라 구현이 어렵다.

이러한 정보를 확인할 수 있는 곳 `whois`
도메인 주소에 대하여 IP주소는 어떤지, 누가 인증한 기관인지에 대한 정보가 나오는 사이트

주요 DNS 서버의 IP주소

- KT : 168.126.63.1
- SKB : 210.220.163.82

```cmd
nslookup www.hufs.ac.kr
서버:  kns.kornet.net
Address:  168.126.63.1

권한 없는 응답:
이름:  www.hufs.ac.kr
Address:  203.232.224.3
```

IP를 추적할 수 있는 명령어 `tracert`

Email(Electronic mail)
구성요소

- User agent
- mail server

메일 서버간 이용하는 프로토콜 : SMTP
송신자가 메일서버로 전달할 때 사용하는 프로토콜 : SMTP
메일서버에서 수신자가 전달 받을 때 사용하는 프로토콜 : IMAP, POP
SMTP, POP, IMAP 은 기본적으로 암호화를 제공하지 않는다.

실제로 받은 메일에서 더보기란의 원문내용을 확인하면 다음과 같다.

Delivered-To: hoyoung.wjd@gmail.com
Received: by 2002:a05:6f02:2148:b0:53:587f:aa8e with SMTP id e8csp3244235rcf;
Thu, 16 Nov 2023 01:35:19 -0800 (PST)
X-Google-Smtp-Source: AGHT+IHTOGusL0uQu027dxJoIHj1Qkk+lV9nFAKKf1eitOFfy3l4uiCtZi8m4gElw8YgCAmJX1aO
X-Received: by 2002:a05:6808:308:b0:3b2:e461:bcfc with SMTP id i8-20020a056808030800b003b2e461bcfcmr15370375oie.20.1700127318611;
Thu, 16 Nov 2023 01:35:18 -0800 (PST)
Return-Path: pty2117@naver.com
Received: from cvsmtppost24.nm.naver.com (cvsmtppost24.nm.naver.com. [114.111.35.237])
by mx.google.com with ESMTPS id j30-20020a63595e000000b005b7dd20f8c1si11404043pgm.20.2023.11.16.01.35.16
for hoyoung.wjd@gmail.com
(version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
Thu, 16 Nov 2023 01:35:18 -0800 (PST)
Received-SPF: pass (google.com: domain of pty2117@naver.com designates 114.111.35.237 as permitted sender) client-ip=114.111.35.237;
Authentication-Results: mx.google.com;
dkim=pass header.i=@naver.com header.s=s20171208 header.b="RIijT/bh";
spf=pass (google.com: domain of pty2117@naver.com designates 114.111.35.237 as permitted sender) smtp.mailfrom=pty2117@naver.com;
dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=naver.com
X-Originating-IP: 220.67.124.107 **보낸사람의 IP주소**
X-Works-Smtp-Source: wrnlKAgmFqJCpNm9KxvdWHF0
Received: from cvsendbo030.nm ([10.112.20.49])
by cvsmtppost24.nm.naver.com with ESMTP id EYJqAoZSTJKvNzvuvEyZ+A
for hoyoung.wjd@gmail.com;
Thu, 16 Nov 2023 09:35:15 -0000

DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/simple; d=naver.com;
s=s20171208; t=1700127315;
bh=2Ijv/I+yNCJThIq8p2untd6t+VjWnI4wITuJ8g7+H6k=; h=Message-
ID:Date:From:To:Subject:From:Subject:Feedback-ID:
X-Works-Security;
b=RIijT/bhwKTBbSIAmyOUxHIiVS2iBuhkAartgNLIMTNJjULMW76Pub577XeG
0f/6C
Ae88NFcDTab6d42wCjBUFX/KbDod5e0/WzM7VGDmT4OhWItYVBo3b0+HLJ/
vXQ85pP
8PNk7ikPjPUR2me9lphsIKdRnHtTjqXxLovUGHB9quw+VVKQqz9URqf7H4hZch
UOAk
4vvMF07eAIbdtM5frQgrk0rMoLFT/3kR3Ig1V7H5YC63+c5tx1IFkwvaCSjQnDc
VAW
/1SuxT+kchsHxIF95OIntu1f/RrkWBuXZmO0AteMEuEhFwNzNJxSsB2XUC5Vk
5MqKj
SF4mPCyZV0jkQ==
X-Session-ID:
GYYwKxKZKAU9FoUwBqMw7XIdDxUwKxbTaAKwKxUXKqgZFov-
MIME-Version: 1.0
Message-ID: 42c3c8e0715e54d0d71d67427465121a@cweb015.nm.nfra.io
Date: Thu, 16 Nov 2023 18:35:14 +0900
From: "정호영" pty2117@naver.com
Importance: normal
To: hoyoung.wjd@gmail.com
Subject: 4.PNG
X-Works-Send-Opt: 3wbwjAIYjHmZFAEwKoJYaxt9KNwtxBmw
Content-Type: multipart/mixed; boundary="-----Boundary-
WM=_7fef1c7f1700.1700127315198"

중앙집중형 서버 시스템에서는 서버를 통해 전달이 이루어지므로 상대방의 IP 주소가 노출되지 않는다. 위의 경우 특정 메일 서버는 송신자의 IP주소를 넣기도 하지만 모두가 그런것은 아니다.
P2P 시스템에서는 서버로부터 상대방의 IP를 받고 직접 연결을 통하여 통신을 하기에 상대방의 IP를 알 수 있다.

풋 프린팅

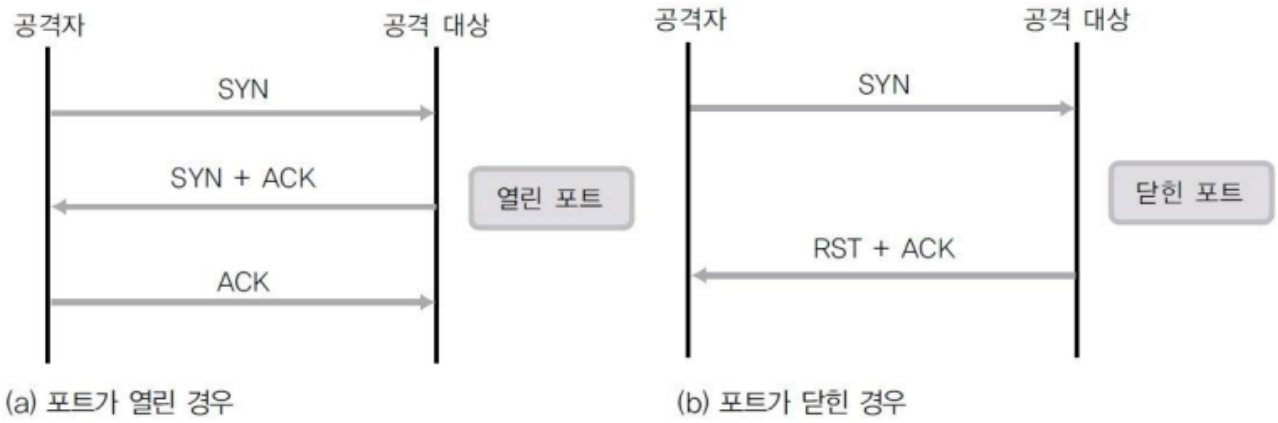
공격 대상의 정보를 모으는 방법을 의미하며 서버의 OS, DB는 어떤 것을 쓰는지, 웹서버는 무엇인지를 알아내는 과정을 말한다.

스캔

서버 존재여부와 서버의 서비스를 확인하는 방법으로 TCP의 연결방법을 이용하여 알아낸다.

포트스캔

HTTP는 80, FTP 21, SSH 22와 같이 유명한 프로그램의 경우 특정 포트를 이용하는데 해당포트로 소켓을 연결하여 서비스가 진행되고 있는지 확인한다.



일반적인 경우 클라이언트가 서버에게 연결을 요청하면 (a)와 같은 모습을 보인다. 하지만 해당 포트가 닫혀있거나 서버가 없다면 서버의 응답으로 SYN+ACK이 아닌 RST(Reset)+ACK 신호가 온다. 서버가 보내는 응답 메시지를 통해서 해당 포트가 열려있는지 확인할 수 있다.

하지만 이는 관리자에 의해 어떠한 공격자가 연결은 했지만 연결만 하고 데이터가 왔다갔다하지않으면 의심당할 수 있고 해당 IP가 차단당할 수 있는 문제가 생긴다.

그래서 연결했다는 로그가 남지 않도록 **스텔스 스캔** 이라는 방법으로 포트를 스캔한다.

서버가 열려있다는 신호인 SYN+ACK가 와도 ACK를 보내 연결하는 것이 아닌 클라이언트가 RST 신호를 보내 강제적으로 연결을 하지 않는 것이며 이는 서버 프로그램의 로그에 남지 않고 포트가 열려있는지 확인할 수 있다.

또한 FIN 스캔 이라는 방법도 있는데 TCP에서 클라이언트가 FIN 메시지를 보내면 서버는 연결을 끊는 시스템을 이용한다. 그래서 처음부터 FIN 메시지를 보내면 서버는 응답을 하지 않을텐데, 닫혀있는 포트나 서버가 없다면 FIN 패킷에도 RST 패킷을 응답하는 것을 통해 포트가 열려있는지 확인할 수 있다.

배너그래빙

배너그래빙은 원격 접속시 안내배너를 사용하는 방법인데 포트를 통해 서버에 연결하고 요청을 보낸다. 클라이언트가 보내는 요청은 받아드릴 수 없는 요청일 수 있지만 서버는 이에 대한 에러메시지를 보일 것이고 이에는 어떤 버전의 OS를 쓰는지, 웹서버의 버전은 무엇인지에 대한 내용이 포함될 수 있다.

방화벽 확인

해당 어플리케이션마다 주로 사용되는 포트번호가 있다는 것은 알고 있는데 방화벽 제품별로 열린 포트를 검색한 후 해당 서버가 A 방화벽을 쓴다는 것이 나오면, A방화벽의 취약점을 조사하고 공격하는 방식이 있다.

8장. 암호의 이해

암호는 평문, 암호화, 암호문, 복호화, 키 로 구성된다.
암호화를 하는 가장 큰 이유는 누군가가 도청을 하여 내용을 가져가더라도 내용을 알아볼 수 없기에, 기밀성을 지킬 수 있다는 것이다.

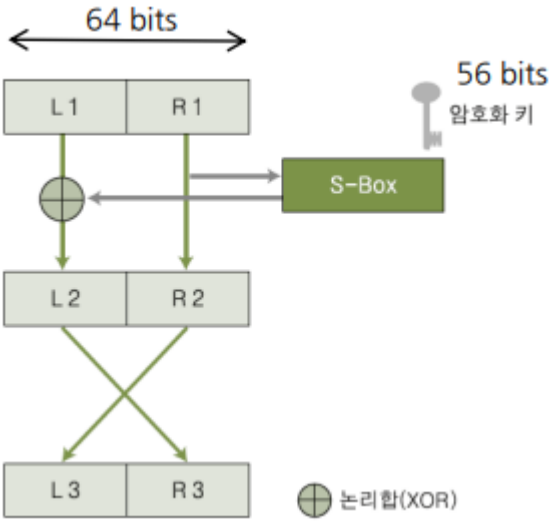
암호의 기본으로 포함해야할 성질은 혼돈과 확산 이다. 혼돈이란 통계적인 성질을 제거하는 것을 말하며 확산은 평문이 조금 달라지더라도 이에 대응되게 암호문도 조금 달라지는 것이 아니라 완전히 다르게 나와야 한다는 것을 의미한다.

암호화 방식은 대칭키 암호화, 비대칭키 암호화 이 있다.
또한 대부분의 암호화방식은 메시지를 블록단위로 짤라서 암호화하는 블록암호화 방식을 사용한다.

대칭키 암호화 방식
암호화와 복호화시 동일한 키를 사용한다. 이는 연산속도가 빠르고 알고리즘이 비교적 간단하다는 장점이 있다.
하지만 누군가가 만든 키가 있을 것이고, 이 키를 해당하는 사람에게 어떻게 전달할 것인가가 문제가 된다.

DES

64bit 블록 암호화, 56bit 암호화 키, 16라운드
S-Box라고 나와있는 것처럼 키는 매번 달라지는 특별한 함수에 의해서 계산되며(혼돈), 마지막에 자리를 바꾸는 확산의 과정이 반복된다.



AES

128bit 블록 암호화, 가변 키 길이(128,192,256), 가변 라운드 수
벨기에 라인델이 제안한 알고리즘, 현재 대부분의 대칭암호화 알고리즘으로 사용된다.

대칭키 암호화 알고리즘

1. SEED(전자 상거래) - 국내
2. ARIA(전자 정부) - 국내
3. HIGHT(저전력, 경량화) - 국내
4. IDEA(키교환에 사용, PGP) - 스위스
5. RC5(간단한 연산) - 미국

비대칭 암호화 방식
대칭키 암호화 알고리즘의 문제점은 과연 키를 어떻게 안전하게 교환할 것인가 라는점이 지적된다.

비대칭 암호화는 두가지 과정으로 이루어진다.

1. 자신은 자신의 개인키/비밀키를 가지고 있다.
2. 자신은 개인키를 가지고 공개키를 생성한다.

RSA

MIT 사람들이 만들었으며, 아주 큰 소수의 곱을 이용하는데, 이는 소인수분해의 어려움을 사용한다. 두 개의 소수(비밀키)를 곱하여 공개키를 만들고 이 공개키는 250자리정도 된다.

△ 내가 가지고 있을 수 있는 키의 수

1. 나의 개인키
2. 나의 공개키
3. N개의 공개키(다른 사람들의 공개키)

case 1. 나의 개인키로 문서를 암호화하는 경우

나의 개인키로 문서를 암호화한다면, 공개키를 가지고 있는 사람들이라면 그 문서를 복호화 할 수 있을텐데 암호화의 의미가 있을까 ?
→ 나의 개인키로 암호화하는 경우, 내가 그사람이 맞다는 신원보증, 부인방지 의 역할로 사용한다.
전자서명에서 주로 사용하는 방식이다.

case 2. 상대방의 공개키로 문서를 암호화하는 경우
상대방의 공개키로 문서를 암호화하여 전달하면 그 문서가 어디에 있어도 그 문서를 복호화할 수 있는 사람은 개인키를 가지고 있는 상대방 한명 뿐이다. 즉 기밀성이 지켜진다 .

	대칭 암호화 방식	비대칭 암호화 방식
키의 상호 관계	암호화 키 = 복호화 키	암호화 키 ≠ 복호화 키
안전한 키 길이	128비트 이상	2048비트 이상
키의 구성	비밀키	공개키, 개인키
예	DES, 3DES, AES	RSA, ECC
제공 서비스	기밀성	기밀성, 부인 방지 및 인증
목적	데이터 암호화	키 교환
단점	별도의 키 교환이 필요하다	공개키 중간자 공격에 취약하다
암호화 속도	빠르다	느리다

해시

해시가 가지는 중요한 특성 중 하나는 일방향성 이라는 것이다.
어떠한 길이의 데이터도 32자리 16진수로 변환하여 문자열을 만든다. 이는 문서의 내용이 위변조되지 않았음을 증명하기 위해 주로 사용된다.

MD5

32개의 16진수로 해시화한다.
주로 위변조가 되지않았다는 것을 증명하는 무결성을 확인하기 위한 수단으로 사용된다.

SHA

MD4가 발전된 형태이며 160bit를 생성한다. MD5에 비해 느리지만 암호화해시는 규칙을 알 수 없도록 설계하여 느리지만 안전하다.

8-1장. 블록체인

분산되고 독립적이며 개방된 장부

은행과 같은 중앙집중형 시스템과 다르며, 각각의 노드들은 서로 통신하고 있다.
블록은 여러개의 트랜잭션이 합쳐진 형태이며, 트랜잭션은 하나의 거래를 의미한다.

블록체인의 분류

	퍼블릭	프라이빗	컨소시움
관리주체	모든 거래 참여자	중앙 기관	컨소시움 참여자
네트워크 참여조건	없음	중앙 기관이 관리	컨소시움 내의 선별된 기관(N개의 기관, N개의 노드)
거래 속도	느림	빠름	빠름
식별성	익명	식별	식별
거래 증명	거래 증명자를 알 수 없다.	중앙기관에 의해 거래 증명(금융기관)	거래 증명자가 알려진 상태
장단점	채굴 필요, 프로토콜 변경의 어려움	속도 빠름, 확장 용이	보안 강화, 확장 용이, 속도 빠름

중앙집중형 거래 시스템을 가지는 경우 프라이빗, 컨소시움 블록체인을 운영하려고 했지만 효과는 미미한듯 보인다.
채굴을 통해서 참여를 유도함.

채굴을 한다는 것은 트랜잭션을 추가한다는 것이며, 블록을 생성하는 것과 같다. 블록의 헤더에는 첫번째 값으로부터 연쇄적으로 해시화된 값이 저장되는데, 첫번째 값을 `난스` 라고 부르며, 난스를 찾아내는 과정을 채굴이라고 한다.

비트코인

세계 최초의 블록체인 기술 기반 암호화폐이며, 분산형 시스템이기에 처리속도가 느리고, 저장공간이 많이 필요하다는 점이 지적된다. 어떠한 해시 알고리즘을 사용하였는지에 대한 내용은 암호화폐 백서를 보고 확인할 수 있으며, 사람들이 채굴을 통해 블록을 생성하면 비트코인을 지급하는 보상을 해준다.

분산형 시스템의 구성되는 노드들이 있을텐데, 모든 거래정보를 알고 있는 `풀 노드` 와 몇몇의 거래정보만 가지고 있는 `라이트노드` 가 있다. 여기서 라이트노드는 거래를 검증하기 위해 풀 노드에게 블록 정보를 요청하여 검증된 거래인지 확인한다. 이러한 확인과정을 `SPV` 라고 한다.

9장. 전자상거래

전자상거래란 인터넷 또는 컴퓨터 네트워크와 같은 전자 시스템으로 제품을 사고 파는 행위를 말하며 온라인 홈뱅킹, 인터넷 쇼핑 등이 있다.

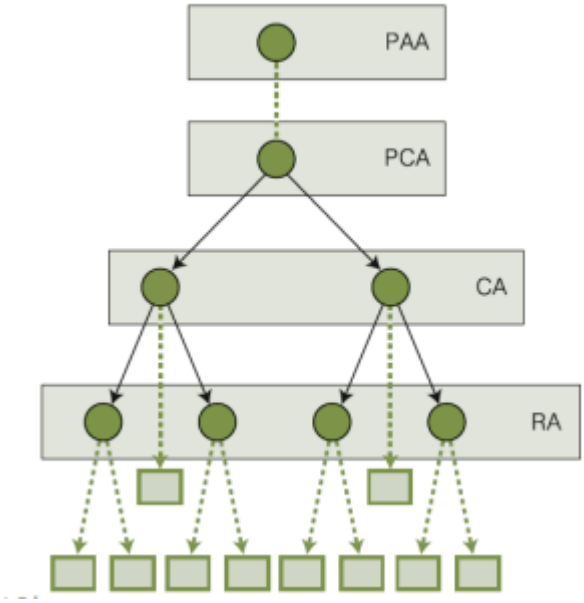
전자상거래의 보안 요구조건

1. 인증 : 다른 사람으로 위장하는지 확인해야한다.
2. 송수신 : 거래내역에 대하여 부인하지 못하도록 하여야 한다.
3. 기밀성 : 거래정보가 유출되지 않도록 해야한다.
4. 무결성 : 거래의 정보가 중간에 변경되면 안된다.
   이러한 요구조건을 지키기 위하여

- 자신과 상대방의 신분 확인 수단 필요
- 거래내역을 공증할 수 있는 신뢰할 수 있는 3자
- 전자지불방식의 안정성 보장하는 수단 필요

공개키기반구조 PKI

메시지 암호화, 전자서명 을 제공하는 보안 시스템을 말하며 인터넷 상에서 신분을 증명할 수 있도록 해준다.



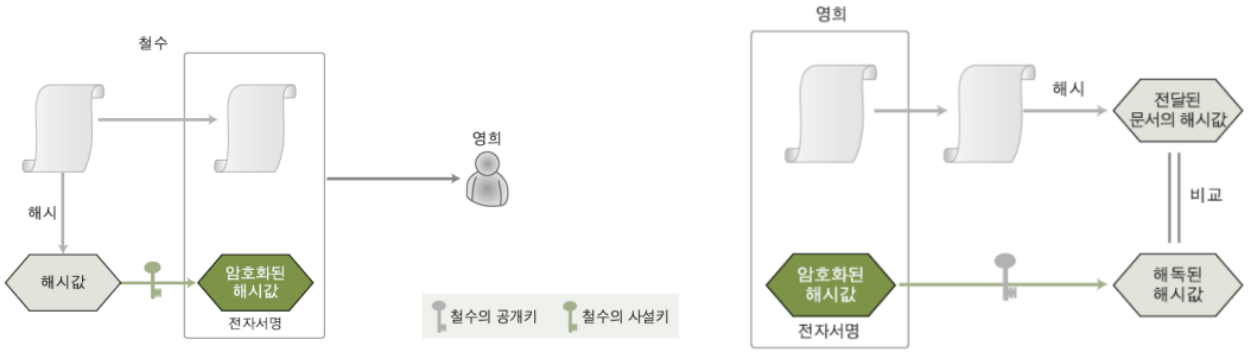
- PAA : 과학기술정보통신부, 정책 승인 기관
- PCA : 한국인터넷진흥원(KISA), 정책 수립 기관
- CA : 인증서 발급과 취소 등 실질적인 업무를 하는 기관(금융결제원, 한국전산원, 대기업 등)
- RA : CA간 인터페이스를 제공하는 기관

사용자는 은행(RA)을 모바일뱅킹을 하려고 할 때 CA(금융결제원)에게 신분을 인증받은 후 거래가 진행된다.

공인인증서
CA가 전자서명하여 생성하며, X.509 버전3 표준으로 정해져있다.
이때 사용자는 CA가 개인키로 서명한 공개키를 가지고 있다.

- 이 사람이 맞다는것은 CA만 증명할 수 있다.

전자서명
위변조 여부, 서명여부 를 확인해야 한다. 다시 말해 원본 내용이 수정되지 않았는지, 양 당사자가 진짜로 서명한것이 맞는지를 확인해야 한다.



철수는 원본문서와 원본 문서를 해시하고 개인키 로 암호화 한 두개의 파일을 영희에게 전달한다.
영희는 원본문서와 철수의 개인키로 암호화된 문서를 받고, 암호화된 문서를 철수의 공개키로 복호화한다. 복호화된 해시문을 해독하여 원본파일과의 비교를 통해 일치한다면 위변조 되지 않았음과, 정말 철수가 보낸 것임을 확인 할 수 있다.

- 원본파일을 그대로 보내기에 기밀성은 지켜지지 않을텐데 ?
  - 전자서명은 위변조 여부와 신원보증 의 역할이 주 임무이고 기밀성을 지키기 위해선 따로 작업을 해주면 된다.

전자서명의 기능

- 위조 불가
- 인증
- 재사용 불가
- 무결성
- 부인 방지

전자결제 SET(Secure Electronic Transaction)
비자와 마스터카드에 의한 프로토콜로 다음과 같다.

- 상점은 고객의 신용카드 정보를 알 필요 없다.

- 은행은 사용자가 무엇을 산지 알 필요 없다.
  → 사용자, 지불 게이트웨이의 공개키, 개인키 를 사용하여 암호화한다.

사용자는 카드를 상점에 인식시킬 것이고, 그 때 전달되는 데이터는 다음과 같다.

지불 게이트웨이만이 자신의 개인키를 가지고 공개키를 복호화하여 사용자가 생성한 비밀키를 획득 할 수 있고 이 정보를 통해 지불정보를 알 수 있다. (상점은 지불정보에 대하여 알지 못한다.)
또한 지불 정보와 구매 정보를 각각 해시하고, 또 각각의 해시를 함께 개인키로 암호화하여 위변조되었는지를 확인한다.

간편결제

삼성페이, 애플페이 등

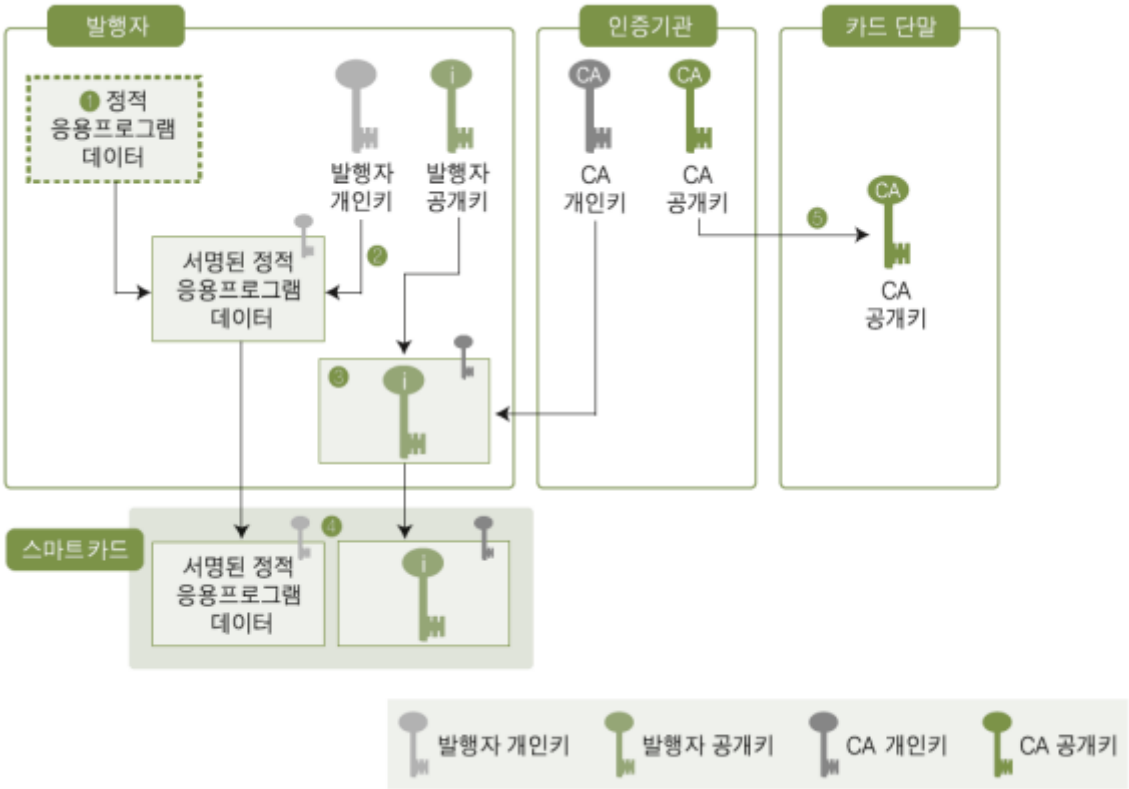
전자 화폐

티머니를 예를 들 수 있고, 이는 빠른 속도를 위해 만들어진 것이기에 실시간성을 보이지 않는다.

스마트카드

1. 접촉식 카드 : IC칩을 사용하고 보안이 중요한 곳에 사용된다.
2. 비접촉식 카드 : 구리선을 이용하여 순간적인 주파수 파장을 전력으로 전환한다. 처리시간에 제한을 받는 곳에 유용하다.

정적 데이터 인증의 카드 발행
회원번호, 카드번호와 같은 정적 데이터의 경우 발행되는 과정의 예는 다음과 같다.



카드 발행사는 카드번호와 같은 정적 데이터를 카드사의 개인키로 암호화한다. 카드사의 공개키를 CA의 개인키로 암호화하여 스마트카드에 포함한다.

[스마트카드에 포함되는 정보]

1. 발행사의 개인키로 암호화된 정적데이터
2. CA의 개인키로 암호화된 발행사의 공개키

정적데이터를 알기위해선, 발행사의 공개키를 알아야하고, 이를 알기 위해서는 CA의 공개키를 알아야 발행사의 공개키를 성공적으로 복호화할 수 있다. 이를 위해 지불게이트웨이가 설치한 카드단말기에는 CA의 공개키가 들어있다. 이를 통해 지불정보와 구매정보를 확인 할 수 있다.

하지만 정적이라는 것은 공격자에 의해 뚤리게 된다면 위험한 상황이고 이에 대응하기 위해 동적 데이터 인증이 나오게 된다. 보안수준이 높고 IC카드 측에 암호화 프로세서가 탑재되어 있다.

암호화 통신

PGP

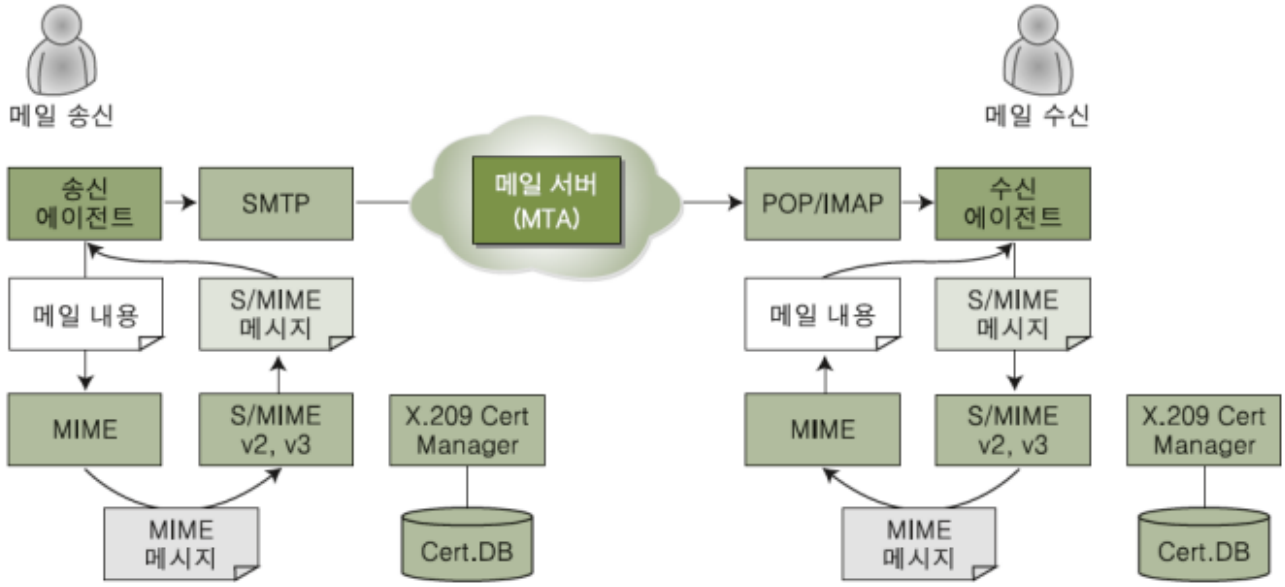
PGP는 공개키, 비밀키를 생성하여 이를 통해 신뢰관계를 인증한다.
주로 이메일 서비스에서 사용되며 어플리케이션 레이어에서 작동한다. 이메일 서비스에서 사

용되는 프로토콜로는 SMTP, POP, IMAP 등이 있는데 이러한 프로토콜들은 암호화를 제공해주지 않는다.

메시지의 기밀성을 지키기위해 송신자, 수신자에서 공개키, 비밀키로 암호화를 진행한다. 이를 통해 메시지의 기밀성, 정말 그사람이 보낸 것이 맞다는 부인봉쇄 의 역할을 할 수 있다.

S/MIME

MIME은 바이너리 데이터를 텍스트로 변환해주는 인코딩방식인데, 여기에 암호화방식을 추가한다.



△ 주의할 점

PGP, S/MIME은 메시지의 기밀성, 부인봉쇄의 역할로 사용하지만, 이메일 서비스의 프로토콜인 SMTP가 적용되기 위해서는 메시지의 헤더부분은 암호화하면 안된다.
헤더부분을 보고 SMTP 프로토콜이 작동하기 때문

인터넷 5 계층에서 사용되는 주요 암호화 프로토콜
5. Application Layer(SSL)
4. Transport Layer
3. Network Layer(IPSec 등)
2. DataLink Layer(PPTP, L2TP 등)

1. Physical Layer

PPTP

데이터링크계층에서 작동되는 암호화 프로토콜로 VPN 프로토콜이다. 외부의 컴퓨터와 서버 내부의 컴퓨터의 직렬 인터페이스를 이용하여 통신할 때 사용한다.

L2TP

데이터링크계층에서 작동되는 암호화 프로토콜로 시스코가 제안한 L2F와 PPTP가 결합된 프로토콜이다.

IPSec

네트워크 계층에서 작동되는 암호화 프로토콜이다.

SSL

어플리케이션 계층에서 작동되는 암호화 프로토콜로 넷스케이프에 의해 개발되었으며 40/128비트의 키를 이용하여 암호화한다. 크게 서버 인증, 클라이언트인증, 암호화 세션 기능을 제공하고 서버는 클라이언트의 인증서를 확인하여 접속할 자격이 있는지 체크한다.

10장. 보안 시스템

인증시스템
주체를 식별하고 이에 대한 인증 서비스를 제공하는 시스템

기본적인 인증시스템은 ID, PW를 통해 인증을 받을 수 있고, 이는 값싸고 편하게 이용할 수 있지만 공격에 취약할 수 있다.

생체조직 : 지문(저렴, 효율성 ↑), 정맥, 손모양 등
생체시스템 : 망막, 홍채, 얼굴
위치 정보 : IP, 콜백 등

SSO(Single Sign on)
모든 인증을 하나의 시스템에서 수행하고, 대기업에서 주로 이용한다.
대기업의 다양한 서비스를 이용하기 위해 대기업의 SSO 서버에서 인증을 받고 이에대한 티켓을 받아 티켓을 통해 기업이 제공하는 다양한 서비스를 이용할 수 있는 권한을 얻게 된다.

방화벽
보안을 높이는 가장 기본적인 방법이며, 빠른 속도를 위해선 HW 방화벽을 이용할 수 있고 필요에 따라 SW 방화벽을 이용할 수 있다. 대표적으로 AWS의 인바운드, 아웃바운드 방화벽은 HW 방화벽으로 구성된다.

방화벽은 외부 IP주소, 포트, 내부 IP 주소, 포트 쌍으로 저장되기에 포함하고 있는 내부 데이터는 검사하지 않는다. 데이터가 악성코드인지 아닌지는 확인할 수 없다.

NAT(Network Address Translation)
NAT은 주로 공유기를 말하는데 사설 주소 IP를 외부 네트워크로 나갈 때 공인 IP로 변환하는 것을 의미하며, IP주소의 부족을 해결하는 방법이다. NAT은 방화벽의 역할로도 쓰이는데, 공격자가 공격을 하기 위해선 상대방의 IP주소를 알아야 하는데, 사설 IP로 감추어져 있기에 직접적으로 공격하지 못한다.

방화벽은 외부에서 내부로 들어오는 공격을 막는다면 만약 이미 내부에 들어와있다면이라는 의문점이 생길 수 있고, 이에 대한 대응 방법으로 IDS, IPS 등이 있다.

IDS(Intrusion Detection System)
네트워크를 통한 공격을 탐지하는 방법이며 **침입 탐지** 가 주요 기능이다.
IDS는 탐지(Detection)이 목표이다

IPS(Intrusion Prevention System)
IDS는 탐지를 목표로 한다면 IPS는 침임을 탐지하고 실시간을 대응하는 시스템을 말한다. 가격은 비싸다.

VPN(Virtual Private Network)
컴퓨터와 컴퓨터 사이 암호화된 터널을 제공하며 회사 외부에서 회사 시스템을 이용하기 위해서 회사 내부망으로 접근할 수 있도록 한다.

기타보안솔루션

NAC(Network Access Control)

IP 관리 시스템의 확장이며 MAC주소를 기반으로 한다.

보안운영체제

커널에 보안 프로그램을 추가로 얹는다.

스팸필터솔루션

주로 메일 시스템에서 이용되며 메일서버의 부하를 막기 위해 앞선에서 미리 DoS공격, 스팸메일, 메일 바이러스를 차단한다. 메일시스템은 그렇게 부하가 크지않기에 스팸필터솔루션이 포함된 메일서버도 존재한다.

DRM(Digital Right Management)

회사 내부에서 만든 문서는 회사내부에서만 이용할 수 있도록 DRM 모듈을 탑재한다. 위치정보와 키를 이용해 암호화한다. 이 문서를 복호화할 수 있는 키는 회사내부 컴퓨터안에 저장되기에 회사내부에서만 이용할 수 있도록 한다.

11장. 침해대응과 포렌식

만약 시스템 내부적으로 침입이 발생하고 그에 따른 손실이 발생한다면 CERT (Computer Emergency Response Team)을 구성하여 대응한다. CERT에는 운영 전문가 뿐 아니라 법률팀도 들어간다.

침입에 대한 등급을 1~3등급으로 나누어 그에 맞게 대응하고자 한다.
침해 등급이 높은 1등급의 경우 네트워크를 끊거나 전원을 끄며 2~3등급의 경우 알려진 대응책에 따라 조치할 수 있도록 한다.

> **△ 전원을 끄는것이 좋을까?**
>
> 침해등급이 높다고 무작정 전원을 끄는것은 좋지 않을 수 있다.
> 시스템은 계속 로그를 남길텐데, 이러한 로그가 저장되지 않고 사라진다거나 공격자가 현재 행동을 어떻게 하는지 파악할 수 있는 방법을 놓치게 될 수도 있기에 적절한 판단이 필요하다.

제일 중요한것은 보안에 대한 사전 훈련이다.

사고를 탐지하기 위한 방법으로 IDS, IPS, 네트워크 트래픽 모니터링(MRTG), 네트워크 관리 시스템(NMS)가 있고 대부분의 서버는 MRTG를 가지고 있기에 이를 통해 분석한다.

1. 퇴근시간 이후 트래픽이 감소해야 하는데 오히려 증가한다. (누군가가 회사 서버를 사용하여 일을 하고 있다.)
2. 피크에서 올라가지 않고 계속 유지된다. (서버의 부하가 심할 것으로 서버를 늘려야 된다.)
등 분석을 통해 미리미리 해결하여야 한다.

디지털 포렌식
컴퓨터 관련 과학적/논리적 절차에 따라 수사하여 법적 효력을 갖도록 하는 방식
이러한 디지털 포렌식은 간접 증거에 해당한다.

포렌식은 정당성(적법한 절차), 재현(실제로 동일한 결과로 재현가능), 신속성(디지털은 빠르게 사라질 수 있기에 신속하게), 연계 보관성(법정까지 오는 과정이 명확히 추적 가능), 무결성의 원칙(위변조 되지 않았음)을 지켜야 한다.

사이버수사기구로는 국가정보원의 국가사이버안보센터, 경찰청의 사이버수사국, 대검찰청의 과학수사부, 사이버수사과가 있다.

시스템의 증거를 수집하는 과정에서 위변조가 되지 않아야 하기에, 적법한 절차에 따라 완전하게 카피를 해야한 뒤 수사를 해야 한다. 그리고 또한 우리가 로그를 지운다고 시스템에서 완전히 사라진다고 생각할 수 있지만, 삭제에도 복호화할 수 있는 이유는 컴퓨터는 문서를 삭제하면 그 문서가 차지하고 있던 메모리공간을 완전히 없애는 것이 아닌 삭제되었다는 기호를 제일

앞이라던지 표시를 남긴다. 그래서 제일 앞의 데이터만 잃게 되고, 이 앞의 데이터만 있으면 완전히 복호화 할 수 있다.
→ 그래서 복원할 때 뒷부분이라도 살았는데 이거라도 복원할까요라고 묻는 이유는 아직 그 뒤쪽 메모리공간이 다른 프로그램에 의해서 덮혀쓰여지지 않았다는 것
→ 가장 큰 실수는 문서를 복원하고자 복원 프로그램을 깔면 제일 앞표시를 보고 여기에는 덮어써도 되겠구나하고 복원하고자 하는 파일이 차지하고 있는 메모리 영역 위에 덮어써버리는 경우 더이상의 복원은 불가능하다.

12장. 사회공학

컴퓨터 관련 뿐 아니라 많은 영역에서 같이 사용하고 있는 단어로 인간 상호 작용 신뢰를 바탕으로 사람을 속여 정상 보안 절차를 깨뜨리고 정보를 얻는 비기술적 침입 수단을 의미한다.
이 중 컴퓨터 기반 사회공학으로 피싱, 파밍(도메인이름을 속이는 행위), 스미싱 등이 존재한다.
→ 해결방법은 역시 충분한 사전 교육이다.

그래서 이를 사전에 예방하기 위하여, 기업은 조직의 보안을 달성하기 위한 구성원들의 지배구조인 정보보안 거버넌스를 구축하여야 한다. 하지만 이는 실질적인 성과가 나오는 것이 아니기에 뚜렷하게 무엇인가 나오기 어렵다.

보안프레임워크는 ISO27001 표준을 따른다. 그렇다면 믿을만하다 라고 생각할 수 있다.
해외의 경우 보안인증으로 TCSEC(미국), ITSEC(유럽), CC(통합), ISMS-P(한국인터넷진흥원)이 있다.